EWB COURSES

CYBERSECURITY ASSESSMENT 01

Security Foundations

Submitted by: Sahil Sanjay Sonawane
Course: AI-Powered Cybersecurity
Total Marks: 100
Date: 22 October 2026

Table of Contents

1. Task A — Secure a Student Account
2. Task B — Analyse a Suspicious Message
3. Task C — Triage a Sign-in Alert
4. Task D — Review an AI Security Answer

Task A: Secure a Student Account

A1. Identify Five Security Risks (10 Marks)

Mira's account and laptop may face several security risks. The CIA triad helps explain their impact. Confidentiality means keeping information private, integrity means preventing unauthorised changes, and availability means being able to access information when needed.

1. Reusing a short password: Mira uses the same short password for her email and learning portal. If someone discovers it, they may access both accounts and view her private information. This affects confidentiality.

2. Approving unexpected sign-in prompts: Mira approves prompts she did not request. Someone else may gain access to her account and change her coursework. This affects confidentiality and integrity.

3. Delaying device updates: Outdated software may contain security weaknesses that attackers can exploit to access or modify files. This affects confidentiality and integrity.

4. Keeping only one project copy: If Mira's laptop is lost or damaged, she may lose her project. This affects availability because she may not be able to access her work.

5. Sharing a signed-in laptop: Her friend may view, change or delete files while using her account. This affects confidentiality and integrity.

A2. Security Controls, Limitations and Priorities (10 Marks)

Mira should use a different, strong password for each account. This reduces the risk of one stolen password exposing both accounts, although phishing can still reveal a password.

She should deny unexpected sign-in prompts and report repeated requests to IT. This helps prevent unwanted access, but it cannot protect her if she approves a malicious request.

Mira should install security updates promptly to fix known weaknesses. However, updates cannot prevent every cyberattack. She should also keep a backup of her project in a secure location. A backup helps recover lost work, but it must also be protected. Finally, she should lock her laptop and give her friend a separate user account. This reduces the chance of someone accessing her private files, although an unlocked session can still expose information.

Priority of Actions

First, Mira should stop approving unexpected sign-in prompts because they may allow someone to access her account. Second, she should change her reused passwords and check for unfamiliar active sessions if she suspects unauthorised access. Third, she should secure her laptop and install pending updates. She should also back up her project as soon as possible.

I would prioritise account security first because unauthorised access could expose personal information. Device protection and backups are also important for preventing further problems and data loss.

A3. Authentication versus Authorisation (5 Marks)

Authentication means checking a user's identity. For example, when Mira enters her username and password into the learning portal and completes the required multi-factor authentication (MFA), the portal checks her identity.

Authorisation means deciding what an authenticated user is allowed to do. Mira may be allowed to view and submit her own assignments, but she should not be allowed to access another student's private grades or change administrator settings.

In simple terms, authentication checks who the user is, while authorisation checks what the user can do.

Task B: Analyse a Suspicious Message

B1. Identify Five Warning Signs (10 Marks)

The scholarship email contains several warning signs. I would check these carefully before trusting the message.

1. Unusual sender address: The sender uses `awards@campus-awards.example`, while the college normally uses `campus.example`. This difference needs verification.

2. Different reply address: The Reply-To address is `help@personal-awards.example`. It differs from the college's usual domain and should be checked.

3. Pressure to act quickly: The subject says, “scholarship expires in 20 minutes.” This creates urgency and may pressure the student into acting without checking the facts.

4. Request for password and OTP: The email asks the student to enter a college password and OTP. Sharing these details could allow someone to access the account.

5. Request for an identity card: The sender asks for a photo of the student's identity card. This could expose personal information and create a privacy risk.

B2. Safe Verification Process (5 Marks)

I would not click the link or reply to the email. Instead, I would open the official college portal using a known address or contact the college office using independently obtained contact details. I would confirm whether the scholarship announcement is genuine before sharing any information.

HTTPS protects the connection between a browser and a website, but it does not prove that the website belongs to the college. A familiar display name can also be copied, so neither is enough to establish that the email is genuine.

B3. Response Plan if Password and OTP Were Entered (7 Marks)

1. **Secure the account:** Use the official college portal to change the password. Change it on other accounts too if the same password was reused.
2. **Contact IT:** Report the incident through an official channel and ask the IT team to secure the account and revoke suspicious sessions.
3. **Check account activity:** Review recent sign-ins and account changes with the help of IT. Follow their instructions for securing MFA.
4. **Report and preserve evidence:** Report the email through the college's designated reporting process and keep the original message for investigation.

The student should never send their password or OTP to anyone, including support staff.

B4. Missing Evidence (3 Marks)

The message alone cannot prove who sent it or who controls the linked website. Full email headers, additional sender information and confirmation from the college could help establish whether the message is genuine.

Task C: Triage a Sign-in Alert

C1. Four-Point Timeline (8 Marks)

1. 09:00–09:01: The logs show a successful password entry followed by approved MFA from the usual classroom IP address, `192.0.2.10`. These events indicate a successful authentication process.

2. 10:14–10:15: Two password attempts from `198.51.100.23` failed. The reason for these failures is unknown.

3. 10:16–10:18: The password was accepted at 10:16. An MFA prompt was denied at 10:17 and approved at 10:18. The student said they approved the prompt because they thought it would stop the repeated requests. This raises concern about possible unauthorised access.

4. 10:20: A session was created from the same source IP address. The student says they did not sign in after 09:05, so the activity needs further investigation.

C2. Likely and Alternative Explanations (7 Marks)

One likely explanation is that someone obtained the student's password and tried to access the account. After the password was accepted, the MFA approval may have allowed the sign-in to continue.

Another possibility is that the activity was connected to a sign-in attempt initiated by the student but not recognised by them, or that a different network connection was involved. The available logs do not establish which explanation is correct.

Two checks could help:

1. Review additional sign-in records, device details and session information to identify whether an unfamiliar device or session was involved.
2. Confirm the student's activity and known devices through an official channel and compare them with the recorded times.

The IP address alone cannot identify the person responsible.

C3. Three Prioritised Response Actions (6 Marks)

1. Protect the account: The IT team should secure the account, reset the password if necessary, revoke suspicious sessions and review MFA settings.

2. Preserve evidence: Save the relevant authentication logs, timestamps, IP addresses and session details before making changes that could remove evidence.

3. Investigate the activity: Review related sign-in records and device information, document the findings and follow the organisation's incident response process.

C4. Incident Summary (4 Marks)

The logs show two failed password attempts, followed by a successful password entry, an MFA denial, an MFA approval and session creation from `198.51.100.23`. The student says they did not sign in after 09:05 but approved a prompt around 10:18. This raises concern about possible unauthorised access, although the logs do not identify who was responsible. The IT team should secure the account, preserve the evidence and investigate the session and device details before reaching a conclusion.

Task D: Review an AI Security Answer

D1. Identify and Correct Five Unsafe Claims (10 Marks)

The supplied AI answer contains five incorrect or unsafe claims.

1. HTTPS proves the email is safe.

HTTPS encrypts the connection, but it does not prove that a website is genuine or trustworthy. The student should verify the scholarship through official college channels.

2. The IP address proves who stole the password.

The logs show activity from `198.51.100.23`, but an IP address alone cannot identify a person or prove who used the account.

3. MFA prevents every account compromise.

MFA adds another layer of security, but it cannot prevent every attack. In this scenario, an unexpected MFA prompt was approved, which may have allowed access.

4. Suspicious logs should be deleted.

The logs should be preserved because they may help the IT team understand what happened and investigate the sign-in activity.

5. The student's password should be sent to support.

Passwords should never be shared with support staff. The student should secure the account through the official portal and contact IT through an authorised channel.

D2. A Better Prompt for an AI Tool (5 Marks)

"Analyse only the fictional evidence supplied in this assessment. Identify the security risks and explain which evidence supports each finding. Separate observed facts from assumptions, consider alternative explanations and clearly state uncertainty. Recommend safe response actions without asking for passwords, OTPs or personal information. Do not claim that an IP address identifies a person or that HTTPS proves a website is genuine."

D3. Corrected Security Advice (6 Marks)

The scholarship email contains warning signs, including urgent language and requests for a password, OTP and identity card. The student should not click the link or share sensitive information. The message should be checked through the official college portal or office. The sign-in logs show suspicious activity followed by MFA approval and session creation, but they do not prove who was responsible. The IT team should secure the account, review active sessions, preserve the logs and investigate the device and sign-in details. Passwords and OTPs should never be sent to support staff. AI-generated advice should be checked against reliable evidence before action is taken.

D4. AI-Use Declaration and References (4 Marks)

AI-use declaration: ChatGPT was used to help organise the assessment answers, explain cybersecurity concepts and improve the wording. The supplied fictional evidence was used for the analysis.

References:

1. CISA — Secure Our World: https://www.cisa.gov/secure-our-world
2. NIST — Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile (AI 600-1): https://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.600-1.pdf